Igor Diego Souza da Silva – HomeLab de Segurança da Informação

🔹 V3 Final – Ataque Automatizado SSH(Brute Force) e Investigação/Resposta ao Incidente

🧠 Objetivo

O V3 teve como objetivo **simular um ataque de força bruta automatizado** contra o usuário vboxuser na VM Ubuntu, coletar e analisar todos os eventos gerados, e documentar uma possível resposta ao incidente de forma profissional, como faria um analista de SOC júnior, finalizando a trilogia do homelab(v1,v2,v3)

🧪 Execução do ataque

- O ataque foi realizado com o **Hydra**, configurado com a wordlist senhas.txt e -t 6 threads, conectando via SSH ao IP da VM alvo.
- Durante a execução, várias tentativas de login foram registradas, incluindo falhas (Failed password) e sucesso (Accepted password).
- **Prints obtidos:**
  - Tela do Hydra mostrando múltiplas tentativas de login
  - Captura dos logs no Splunk mostrando **IP do atacante, hora e usuário alvo**, com linhas de falha e sucesso

---

🔍 Captura e análise dos logs

- O Splunk monitorou o arquivo `/var/log/alt.log` (ou `auth.log`), capturando **todos os eventos gerados pelo ataque automatizado**, através de criação de inputs.txt manual para o splunk.
- A análise mostrou:
  - **Tentativas falhas:** múltiplas, do mesmo IP atacante
  - **Tentativa bem-sucedida:** identificada e registrada com timestamp
- Essa análise permitiu identificar **padrões do atacante**, incluindo IP de origem, número de tentativas e horários de atividade.

🧠 Resposta simulada ao incidente

Baseado nos dados capturados, algumas ações poderiam ser aplicadas em um ambiente real:

1. Bloqueio do IP atacante

O bloqueio imediato do IP responsável pelas tentativas de login impede novas tentativas de comprometimento.
Essa ação reduz o risco de exposição da conta alvo e limita o alcance do ataque.
Em ambientes reais, o bloqueio pode ser aplicado via firewall, regras de rede ou configuração no próprio servidor SSH.

2. Alertas automáticos no Splunk

Configurar alertas para detectar múltiplas tentativas falhas permite notificação em tempo real para a equipe de segurança.
Essa abordagem é proativa, permitindo ações rápidas antes que o ataque seja bem-sucedido.
Definir thresholds, por exemplo 3 tentativas falhas por usuário, ajuda a equilibrar sensibilidade e minimizar falsos positivos.

3. Revisão e fortalecimento de políticas de senha

A análise evidenciou que a senha do usuário alvo foi descoberta pelo ataque automatizado.
Políticas de senha fortes, autenticação multifator e conscientização dos usuários sobre boas práticas são essenciais para reduzir a eficácia de ataques de força bruta.
Fortalecer senhas e implementar controles de autenticação evita que ataques simples comprometam contas críticas.

4. Documentação completa do incidente

Todos os eventos foram registrados no Splunk, incluindo horários, IPs, usuários e resultados das tentativas.
A documentação permite auditoria futura, análise de padrões e suporte à melhoria contínua da segurança.
Também fornece base para relatórios de compliance e acompanhamento das ações de mitigação.

5. Insights adicionais

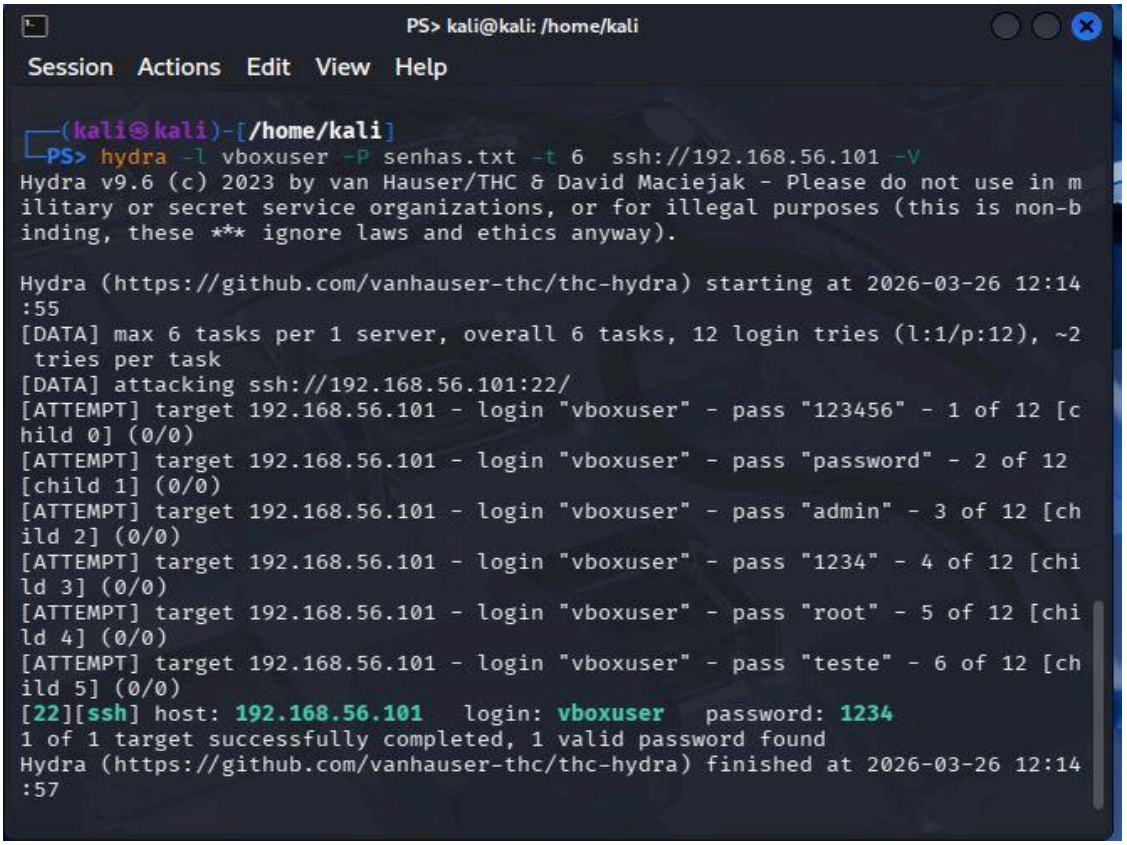
A combinação de bloqueio de IP, alertas e revisão de senha cria uma camada de proteção que não apenas reage, mas previne futuras tentativas.
A análise dos logs permite identificar padrões de comportamento do atacante, como horários de maior atividade e usuários mais visados.
Esse processo reflete o ciclo completo de um SOC: detecção → análise → resposta → mitigação, reforçando a postura de segurança da organização.

🧠 Aprendizado e valor do V3

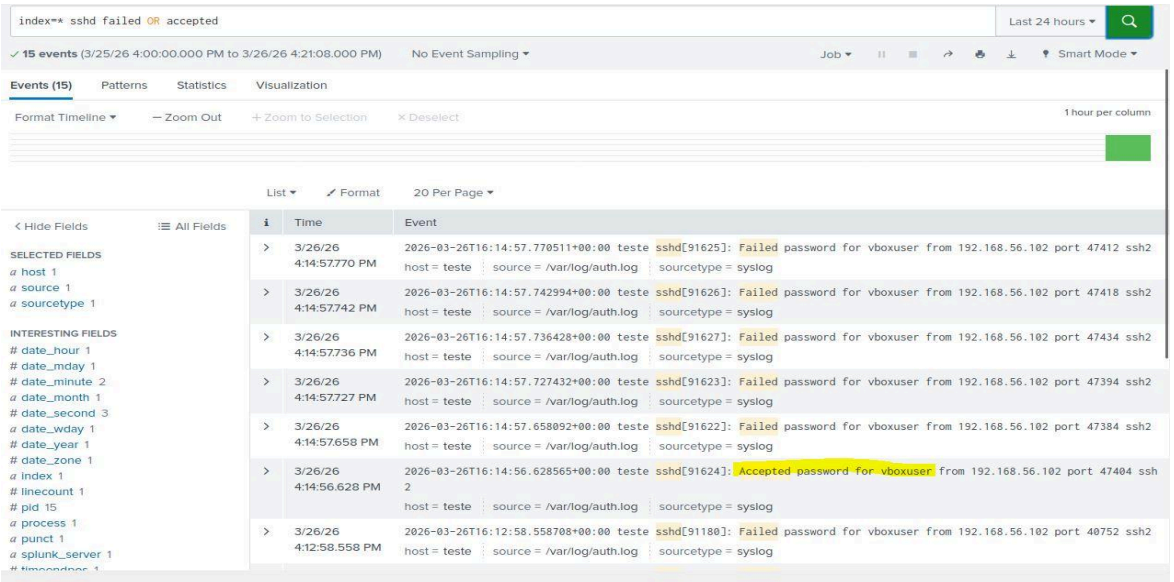
- Demonstra a capacidade de **detectar ataques automatizados**.
- Ensina a interpretar **padrões de ataque**, entender risco e volume de tentativas
- Permite criar **resposta simulada de SOC**, transformando dados brutos de logs em ações concretas de segurança.
- Reforçar habilidades em **Splunk, Linux e análise de incidentes**.

📸 Evidências

1) Ataque realizado via VM Kali, utilizando Hydra.



2) Validação do ataque brute force, via splunk



🧠 Conclusão

O V3 complementa o V2, destacando:

- Ataque automatizado com Hydra (`-t 6`)
- Logs capturados com sucesso, incluindo IP, hora e resultado
- Análise de padrão do atacante e respostas possíveis
- Documentação e evidências claras, bem como respostas possíveis ao incidente.
- Reforço de prática em ambiente splunk, linux e detecção/resposta a incidentes.